

GRC TRACK — PROJECT RESOURCE PACK

MedCore Clinics

Phase: Design / Pre-Implementation — nothing described here has been built yet

Approach: Qualitative Risk Assessment

How to Use This Pack

This document is your working resource for the MedCore Clinics GRC project. It is written the way a real organization's design-phase documentation would look before a system goes live — that's intentional. In a real job, nobody hands a GRC analyst a clean asset inventory or a list of risks. You build the asset inventory yourself by reading design and architecture documentation, and you derive risks from what that documentation exposes (or fails to address).

There are three parts to this pack:

1. Section 2 — The scenario and business context (why this project exists, who the stakeholders are, what "done" looks like).
2. Section 3 — Design & Architecture documentation for the fictional organization (system design, data flows, network design, third parties, planned controls). Treat this exactly as you would a real design package handed to you before go-live.
3. Section 4 — Your deliverables, with the methodology, templates, and scoring scales you must use, so both teams in this category are graded on the same basis.

Work only from what is written in Section 3 plus reasonable, clearly-labelled assumptions. If you assume something that isn't stated, write it down as an assumption in your report — don't silently invent facts.

2. Scenario & Business Context

MedCore Clinics is a chain of 14 outpatient clinics operating across three cities. Historically each clinic kept patient records in a locally-installed practice-management application with paper backups. Leadership has approved a project to migrate all patient records to a single cloud-based Electronic Health Record (EHR) platform so that any clinic can pull up any patient's history, appointments can be scheduled centrally, and billing can be consolidated. No security function currently exists at MedCore beyond a shared IT helpdesk contractor; there is no security policy, no formal access control process, and no prior risk assessment on file.

The project is in the design phase. Executive sponsors have approved the architecture described in Section 3 and asked the (fictional) GRC function to deliver a risk assessment, a control gap analysis against a recognized framework, and a prioritized remediation plan before any development or migration work begins.

Stakeholders

- Clinical Directors (3) — accountable for patient care continuity; care about system uptime and clinician usability
- Chief Operating Officer — project sponsor; accountable for the business case and go-live date
- Billing & Revenue Cycle Manager — owns claims/insurance data flows
- IT Helpdesk Contractor (3rd party, 4 staff) — currently the only technical resource; will operate the new platform post-launch
- Patients — data subjects; no formal representation, but regulatory obligations exist on their behalf

Regulatory Context

MedCore treats patients in a jurisdiction where health data is subject to data-protection and health-privacy regulation (treat this as broadly equivalent to HIPAA-style obligations for the purposes of this exercise: breach notification duties, minimum-necessary access, and audit trail requirements for patient data). Assume these obligations apply and factor them into your impact ratings.

3. Design & Architecture Documentation

The following was produced by MedCore's solutions architect and vendor during design workshops. Nothing described below has been implemented. Use it as your source of truth for the asset inventory and risk analysis.

3.1 System Overview

- Platform: Multi-tenant, cloud-hosted EHR SaaS product ("ClinicCloud"), operated by a third-party vendor. MedCore is one tenant among many customers on shared infrastructure.
- Access model: Each of the 14 clinics accesses ClinicCloud through a web browser over the public internet — no VPN or dedicated link is currently planned.
- Authentication: Single username/password per staff member, stored and managed by the SaaS vendor. Multi-factor authentication is available from the vendor as an add-on but has not yet been enabled in the design.
- Roles: Two roles are defined so far — "Clinician" (full read/write to assigned patients) and "Front Desk" (scheduling and demographic data only). No distinction yet between clinic locations — a Clinician role at any clinic can currently see patients from any other clinic.
- Data migration: Legacy records from the 14 local practice-management systems will be exported to CSV, uploaded to a shared folder, and bulk-imported into ClinicCloud by the vendor's migration team.
- Devices: Clinics will continue using existing clinic-owned Windows laptops (average age ~4 years, patch status unknown/unmanaged) to access ClinicCloud via Chrome browser.

3.2 Logical Architecture / Data Flow (as designed)

- Clinic Workstation (Chrome browser) --HTTPS--> ClinicCloud Web App (vendor-hosted)
- ClinicCloud Web App --internal vendor network--> ClinicCloud Application Servers
- ClinicCloud Application Servers --internal--> ClinicCloud Primary Database (patient records, PII/PHI, appointment data)
- ClinicCloud Application Servers --API, HTTPS--> Third-Party Billing Clearinghouse (submits insurance claims containing patient demographic + diagnosis codes)
- ClinicCloud Application Servers --API, HTTPS--> SMS/Email Appointment Reminder Service (3rd party; receives patient name, phone/email, appointment time)
- Legacy Practice-Management Systems (14 clinics) --CSV export, uploaded to vendor-provided shared folder over HTTPS--> ClinicCloud Migration Pipeline (one-time bulk import)
- ClinicCloud Application Servers --automated nightly backup--> Vendor Backup Storage (region and encryption status not yet specified in the design)
- IT Helpdesk Contractor --remote access tool (product TBD)--> Clinic Workstations, for troubleshooting

3.3 Data Classification (as documented by the vendor)

Data Element	Where It Lives	Sensitivity (vendor's stated classification)
Patient name, DOB, address, phone	ClinicCloud Primary DB, Reminder Service, Clearinghouse	Confidential (PII)
Diagnosis codes, clinical notes	ClinicCloud Primary DB	Restricted (PHI)
Insurance/billing details	ClinicCloud Primary DB, Clearinghouse	Confidential
Appointment schedule	ClinicCloud Primary DB, Reminder Service	Internal
Staff login credentials	ClinicCloud vendor identity store	Restricted
Legacy CSV export files (in shared folder pending import)	Shared migration folder	Restricted (unclassified by vendor in design — flagged by architect as open item)

3.4 Planned / Stated Controls

- Vendor states ClinicCloud is "ISO 27001 certified" for its own data center operations (certificate not yet provided to MedCore for review).
- TLS 1.2 in transit for all vendor-stated connections.
- Encryption at rest: vendor's sales documentation says "data is encrypted" but the design package does not specify algorithm, key ownership, or key rotation.
- No MedCore-side logging or monitoring is currently designed — audit logs, if any, exist only inside the vendor's platform, and MedCore has not asked for access to them.
- No offboarding process is defined for the migration folder, the reminder service, or the clearinghouse integration once migration is complete.
- No incident response plan or breach notification procedure exists at MedCore.
- No vendor risk assessment or contract security addendum has been completed for ClinicCloud, the clearinghouse, or the reminder service.
- Password policy: none defined beyond the SaaS vendor's default (8-character minimum, no complexity or rotation rule confirmed).
- No network segmentation applies — this is a pure SaaS model; MedCore's exposure is concentrated in its own endpoints, identities, and third-party integrations.

3.5 Open Items Flagged by the Architect (use these as gap-analysis seeds)

- MFA: available but not enabled — decision pending
- Clinic-level access segmentation (patients visible only to their own clinic) — not yet designed
- Backup encryption and region — unconfirmed
- Remote access tool for the helpdesk contractor — not yet selected
- Data retention/disposal policy for legacy CSV exports post-migration — not written
- Vendor contract security terms (breach notification SLA, right-to-audit) — not yet negotiated

4. Your Deliverables

You are acting as the GRC team for this organization during its design phase. Your job is to tell the organization what could go wrong before it goes live, how bad each thing would be, and what to fix first — mapped to a recognized framework. Everything is qualitative: no dollar-value loss modeling, no ALE/SLE calculations. Use descriptive scales (Low/Medium/High/Critical) throughout.

4.1 Asset Inventory (build this first)

Before you can assess risk you need to know what you're protecting. Read Section 3 and extract every asset into a register. An asset is anything of value: a system, a data store, an interface, a credential set, a piece of infrastructure, or a third party with access. For each asset, capture:

- Asset ID and name
- Asset type (data / application / infrastructure / third party / process)
- Description and owner (infer a reasonable owner if not stated, and label it as inferred)
- Data classification or criticality (Public / Internal / Confidential / Restricted)
- Where it sits in the architecture (which zone / network segment / environment)

Target: a minimum of 12 distinct assets, pulled directly from the design documentation, not invented.

4.2 Framework Mapping

Pick one recognized framework and use it consistently across the whole report: ISO/IEC 27001:2022 Annex A, or NIST CSF 2.0. State which one you chose and why it fits this organization in one paragraph. Every gap and every risk in your report must reference at least one control or function from that framework (e.g., "ISO 27001 A.8.24 – Use of cryptography" or "NIST CSF PR.DS-01").

4.3 Gap Analysis

For each relevant control area in your chosen framework, assess the organization's design against it in three states: Not Addressed / Partially Addressed / Fully Addressed. This is a design-phase gap analysis — you are checking whether the design documentation shows evidence of intent to implement the control, not whether it's actually running yet. Build a table with these columns:

- Control reference (framework ID)
- Control area / requirement
- Current state per the design docs (Not / Partially / Fully Addressed)
- Evidence or citation from Section 3 supporting your rating
- Gap description — what's missing and why it matters

Minimum 15 control areas assessed.

4.4 Qualitative Risk Matrix (minimum 12 risks)

Use the standard 5x5 Likelihood x Impact matrix and scoring scale below for both GRC teams — this keeps scoring consistent across teams so results are comparable.

Score	Rating	Design-Phase Definition
1	Rare	Would require multiple independent failures or highly unusual conditions; no realistic path in this design.
2	Unlikely	Possible but design includes some mitigating factor; would need an uncommon trigger.
3	Possible	Plausible given how the design is described; comparable issues are common in similar systems.
4	Likely	Design leaves an evident, exploitable gap; expected to occur without intervention.
5	Almost Certain	Design has no meaningful control against this; near-guaranteed given normal operating conditions.

Score	Rating	Design-Phase Definition
1	Negligible	No material effect on operations, data, safety, or compliance.
2	Minor	Localized, short-lived disruption; no sensitive data or safety exposure.
3	Moderate	Noticeable service disruption or limited data exposure; recoverable within normal operations.
4	Major	Significant disruption, breach of sensitive/regulated data, or safety near-miss; regulatory attention likely.
5	Severe	Extended outage, large-scale data breach, safety incident, or existential regulatory/legal consequence.

Risk Score = Likelihood x Impact. Risk Level bands: 1-4 Low, 5-9 Medium, 10-15 High, 16-25 Critical.

Likelihood \ Impact	1	2	3	4	5
5	5	10	15	20	25

Likelihood \ Impact	1	2	3	4	5
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

For each risk in your register, capture:

- Risk ID
- Risk description (threat + vulnerability + affected asset, one sentence)
- Related framework control(s) from your gap analysis
- Likelihood rating (1-5) with one-line justification
- Impact rating (1-5) with one-line justification
- Risk score and level
- Existing/planned controls (if any, per the design docs)
- Recommended treatment (Mitigate / Transfer / Accept / Avoid) and specific recommendation

Minimum 12 risks, and they must trace back to real elements of the architecture in Section 3 — not generic textbook risks copy-pasted without context.

4.5 Business Impact Analysis (BIA) — qualitative

For the organization's 4-6 most critical business processes or systems (drawn from Section 3), assess:

- Process/system name and description
- Criticality tier (Mission-Critical / Important / Standard)
- Impact of disruption across four dimensions, rated Low/Medium/High/Severe each: Financial, Operational, Reputational, Legal/Regulatory
- Maximum Tolerable Downtime (MTD) — a qualitative estimate (e.g., "minutes", "hours", "1-2 days") with justification
- Recovery Time Objective (RTO) and Recovery Point Objective (RPO) — qualitative estimates with justification
- Dependencies (systems, vendors, or processes this relies on)

4.6 Prioritized Remediation Roadmap

Take your risk register and gap analysis and produce a prioritized action list an executive could actually approve. Group into three horizons:

- Before go-live (must-fix — blocks launch)
- First 90 days post-launch
- Longer-term / continuous improvement

For each item: what to do, which risk(s)/gap(s) it addresses, rough effort (Low/Medium/High), and owner (role, not a name).

4.7 Executive Summary & Presentation

A one-page executive summary written for a non-technical board: overall risk posture in plain language, top 3-5 risks, and the single most important recommendation. Your team will also present a 10-12 minute walkthrough of your findings, in the roles listed in your scenario card (Risk Analyst, Compliance Officer, Threat Modeler, Control Owner/Auditor, Policy Writer, Team Lead/Presenter — or the OT-specific role set for Atlas).

4.8 Policy Document (required)

The team must produce one real, standalone policy document (1-2 pages) directly addressing the single highest-priority gap identified in Section 4.3. This is a governance artifact, not a summary — it must read like something an organization could actually adopt. Required structure:

- Purpose — why this policy exists
- Scope — who and what it applies to
- Policy statements — numbered, testable rules (e.g., "All remote access to [system] must use multi-factor authentication"), not vague intentions
- Roles & responsibilities — who enforces and who complies
- Enforcement & exceptions — what happens on violation, and how an exception is requested/approved

4.9 Format Checklist

- Named framework stated up front (ISO 27001 or NIST CSF) and used consistently
- Asset inventory: 12+ assets, sourced from Section 3
- Gap analysis: 15+ control areas, each with evidence/citation
- Risk matrix: 12+ risks, scored with the shared 5x5 scale
- BIA: 4-6 critical processes, four impact dimensions, MTD/RTO/RPO
- Remediation roadmap: 3 horizons, owner + effort per item
- One standalone policy document (1-2 pages) addressing the top-priority gap, with numbered testable policy statements
- One-page executive summary
- All assumptions explicitly labeled as assumptions

5. Team Roles & Task Breakdown

Six roles are named on your scenario card. Each one below has a specific piece of the project to own — every role produces something that ends up in the final report, and no role is a spectator.

Risk Analyst

- Build and own the qualitative risk register (Section 4.4) — minimum 12 risks, each scored with the shared 5x5 Likelihood x Impact scale.
- Justify every Likelihood and Impact rating in one line, tied to something specific in the design documentation.
- Recommend a treatment (Mitigate / Transfer / Accept / Avoid) for each risk.

Compliance Officer

- Choose and justify the framework (ISO 27001 or NIST CSF) for the whole report.
- Build the gap analysis table (Section 4.3) — minimum 15 control areas, each rated Not/Partially/Fully Addressed with evidence cited from the design docs.
- Flag which gaps represent a regulatory exposure (breach notification, minimum-necessary access, audit trail) given MedCore's regulatory context.

Threat Modeler

- Produce a short threat model of the ClinicCloud data flow: list realistic threat actors (e.g., malicious insider at a clinic, compromised helpdesk contractor, credential-stuffing attacker, careless vendor) and the attack path each could take through the architecture in Section 3.
- Feed these attack paths into the Risk Analyst's register as the "threat" half of each risk description.

- Identify at least one plausible multi-step attack chain (e.g., stolen laptop -> no MFA -> full patient record access) and write it up as a short narrative.

Control Owner / Auditor

- Independently verify every piece of evidence cited in the Compliance Officer's gap analysis — check that the citation actually supports the rating given.
- Own the Business Impact Analysis (Section 4.5): identify MedCore's 4-6 most critical processes/systems, rate impact across Financial/Operational/Reputational/Legal, and estimate MTD/RTO/RPO.
- Sign off (in writing, one paragraph) on whether the gap analysis and BIA are internally consistent before the report is finalized.

Policy Writer

- Write one real, standalone policy document (1-2 pages) that directly addresses the single highest-priority gap identified by the team — for MedCore this will likely be an Access Control Policy or a Third-Party/Vendor Data Handling Policy.
- The policy must include: purpose, scope, policy statements (numbered, testable rules — not vague intentions), roles/responsibilities, and enforcement/exception handling.
- Translate the team's remediation roadmap (Section 4.6) into the specific policy statements it implies — the roadmap and the policy should visibly connect.

Team Lead / Presenter

- Own the executive summary (Section 4.7) — one page, plain language, top 3-5 risks, single most important recommendation.
- Integrate all sections into one coherent final report and check for consistency (same framework language, same risk IDs referenced consistently across sections).
- Lead the 10-12 minute team presentation and coordinate who presents which section.

6. Ground Rules

- Do not ask the instructor for the asset inventory — it is your job to extract it from Section 3.
- Every risk and gap must cite something concrete from the design documentation (a section, a diagram element, a stated data flow).
- If information isn't in the design docs, state your assumption clearly rather than guessing silently.
- Stay qualitative throughout — no fabricated financial figures.
- Use one framework consistently; do not mix ISO 27001 and NIST CSF language in the same control reference.

MedCore team — you are being graded on rigor of reasoning, traceability to the design docs, and how defensible your prioritization is in front of the class — not on volume.